

Security Risk Assessment

Ticket #005 — Security Risk Assessment

Executive Summary

CyberOps Defense Group evaluated CVE-2021-42013 affecting Apache HTTP Server 2.4.50 on the simulated Employee Operations Portal.

The vulnerability is Critical by published severity and has known real-world exploitation.

Testing confirmed that Apache 2.4.50 was installed, running, and reachable on the lab network.

However, environment-specific investigation identified compensating controls that materially reduced observed exploitability.

No evidence of active exploitation was identified.

The initial risk was therefore assessed as significant but not sufficient to justify immediate business-hours shutdown.

CyberOps selected an expedited controlled remediation approach.

Apache HTTP Server was successfully upgraded from version 2.4.50 to 2.4.68 while maintaining application functionality.

Final residual risk is assessed as LOW-MEDIUM.

Recommendation confidence is HIGH.

1. Asset and Business Context

Asset

Employee Operations Portal

Host

ubuntu-soc-lab

Operating System

Ubuntu 24.04.4 LTS

Application Address

192.168.56.121:8081

Business Function

The system represents a business-critical internal application used by employees.

Loss of availability during active business hours could interrupt normal operations.

2. Vulnerability

CVE

CVE-2021-42013

Product

Apache HTTP Server

Vulnerable Version Observed

Apache HTTP Server 2.4.50

Severity

CVSS v3.1 Base Score: 9.8 — Critical

Attack Characteristics

Attack Vector: Network

Attack Complexity: Low

Privileges Required: None

User Interaction: None

Potential Impact

Potential impact includes:

- Unauthorized file access
 - Sensitive information disclosure
 - Remote code execution under vulnerable configurations
 - Web-service compromise
 - Application disruption
-

3. Vulnerability Status

Installed

YES

Running

YES

Reachable

YES

Vulnerable by Version

YES

Apache HTTP Server 2.4.50 was confirmed through direct version inspection and HTTP response headers.

4. Exposure Assessment

The service was reachable at:

192.168.56.121:8081

The service was bound to the dedicated lab interface rather than every host interface.

This reduced network exposure but did not eliminate reachability.

5. Exploitability Assessment

Environment-specific investigation identified the following controls.

Filesystem Restriction

Apache was configured with:

AllowOverride none Require all denied

This restricted general filesystem access.

CGI Configuration

A ScriptAlias for /cgi-bin/ existed.

However, neither cgi_module nor cgid_module was observed in the loaded module list.

The remote-code-execution prerequisites associated with CGI were therefore not observed.

Application Content

Application content was mounted read-only.

Network Exposure

The service was bound specifically to:

192.168.56.121:8081

rather than 0.0.0.0.

Exploitability Conclusion

Vulnerable: YES

Exploitable in the observed configuration: NOT DEMONSTRATED

Remote Code Execution Prerequisites: NOT OBSERVED

6. Evidence of Active Exploitation

Apache access and runtime logs were reviewed.

Search patterns included:

- encoded traversal sequences
- ../ traversal
- /etc/passwd
- /bin/sh
- CGI-related requests

The only CGI-related request observed was generated by the analyst during authorized validation.

No unexplained evidence of exploitation was identified.

Active Exploitation Conclusion

NO EVIDENCE IDENTIFIED

This conclusion does not prove that exploitation was impossible.

7. Initial Security Risk

Likelihood

MEDIUM

Factors increasing likelihood:

- Known vulnerable Apache version
- Network-reachable service
- Vulnerability has known real-world exploitation
- No authentication is required for the underlying vulnerability

Factors reducing likelihood:

- Filesystem root access denied
- CGI execution modules not observed
- Limited network binding
- No suspicious activity identified

Impact

HIGH

Successful exploitation could affect confidentiality, integrity, and availability of the application or underlying system.

Initial Risk Rating

HIGH

The vulnerability had serious potential impact and known exploitation history, but observed controls reduced the likelihood of successful exploitation in this specific environment.

8. Operational Risk

Immediate remediation also created risk.

Potential operational consequences included:

- Employee interruption
- Application downtime
- Upgrade incompatibility
- Unexpected configuration problems
- Extended outage if rollback failed

Immediate Shutdown Operational Risk

HIGH

Immediate Emergency Upgrade Operational Risk

MEDIUM-HIGH

Expedited Controlled Upgrade Operational Risk

LOW-MEDIUM

Waiting Until Weekend Operational Risk

LOW

9. Response Options

Four options were evaluated.

Option 1

Immediate shutdown and remediation

Security protection: Strongest

Operational impact: Highest

Decision-matrix score: 18 / 30

Option 2

Immediate business-hours emergency upgrade

Security protection: Strong

Operational impact: Medium-High

Decision-matrix score: 21 / 30

Option 3

Interim controls plus expedited remediation

Security protection: Strong with temporary residual exposure

Operational impact: Low-Medium

Decision-matrix score: 26 / 30

Option 4

Wait until normal weekend maintenance

Security protection: Lowest of the four options during the waiting period

Operational impact: Lowest

Decision-matrix score: 24 / 30

10. Risk Decision

Selected Response:

OPTION 3 — INTERIM CONTROLS + EXPEDITED REMEDIATION

The application remained operational while:

- existing compensating controls were verified,
- security monitoring continued,
- a patched replacement was prepared,
- functional testing was performed,
- and rollback capability was preserved.

The upgrade was then performed through a controlled cutover.

11. Why Immediate Shutdown Was Not Required

Immediate shutdown would have minimized vulnerability exposure but created substantial business disruption.

The available evidence did not demonstrate:

- active exploitation,
- successful traversal,
- remote command execution,
- enabled CGI execution modules,
- or failed filesystem protections.

Therefore immediate shutdown was not considered proportionate to the observed risk.

This conclusion would have changed if those conditions changed.

12. Why Waiting Until the Weekend Was Not Selected

Platform Operations had a reasonable argument for waiting.

Existing controls reduced exploitability, and no active exploitation was identified.

However, Apache 2.4.50 remained vulnerable and reachable.

Waiting several additional days would knowingly extend the exposure period.

An expedited controlled remediation provided a better balance.

13. Remediation

Apache HTTP Server was upgraded from:

2.4.50

to:

2.4.68

The replacement was tested on an alternate port before production cutover.

The vulnerable Apache 2.4.50 container was stopped and preserved for rollback.

14. Implementation Complication

Post-change monitoring identified:

AH00558: Could not reliably determine the server's fully qualified domain name.

The application continued to operate normally and Apache configuration testing returned:

Syntax OK

Investigation determined that no global ServerName directive existed.

The configuration was corrected with:

ServerName employee-portal.internal

The correction was tested separately before deployment.

Final validation confirmed that the warning was eliminated without affecting application functionality.

15. Final Validation

Security Validation

PASS

Apache version: 2.4.68

Configuration: Syntax OK

ServerName: employee-portal.internal

Functional Validation

PASS

HTTP response: 200 OK

Employee Operations Portal: Operational

Operational Validation

PASS

Active container: Running

TCP port 8081: Listening

Unrelated services: Unaffected

Monitoring Validation

PASS

Normal Apache startup and request logging were observed.

No AH00558 warning remained.

16. Residual Security Risk

The specific active exposure associated with Apache 2.4.50 has been removed.

Residual security risk remains from:

- future Apache vulnerabilities,
- application vulnerabilities,
- operating-system vulnerabilities,
- Docker/platform vulnerabilities,
- network exposure,
- configuration changes,
- and incomplete attack detection.

Residual Security Risk Rating

LOW

17. Residual Operational Risk

Operational risk remains because:

- the application uses a single active container,
- failover was not demonstrated,
- future updates may introduce compatibility problems,
- configuration changes may cause outages,
- and host failure could interrupt service.

Residual Operational Risk Rating

LOW-MEDIUM

18. Overall Residual Risk

LOW-MEDIUM

The identified vulnerability has been remediated, but normal infrastructure and application risks remain.

19. Recommendation Confidence

HIGH

Confidence is supported by:

- direct version evidence,
- container-state evidence,
- HTTP validation,
- network-listener evidence,
- Apache configuration inspection,
- Apache module inspection,
- log review,
- pre-change testing,
- post-change validation,
- and final monitoring validation.

Remaining uncertainty relates primarily to differences between the lab and a real production environment.

20. Conditions That Would Have Changed the Decision

Immediate containment would have been reconsidered if:

- exploitation evidence appeared,
 - traversal attempts were observed,
 - command execution was identified,
 - CGI execution became enabled,
 - filesystem access restrictions were weakened,
 - network exposure increased,
 - compensating controls failed,
 - or compromise was confirmed.
-

Final Risk Decision

CyberOps Defense Group determined that an immediate shutdown was not required based on the observed environment.

However, indefinite reliance on compensating controls was also not appropriate.

The selected expedited controlled remediation successfully reduced the security risk while preserving business continuity.

Final Overall Residual Risk:

LOW-MEDIUM

Recommendation Confidence:

HIGH